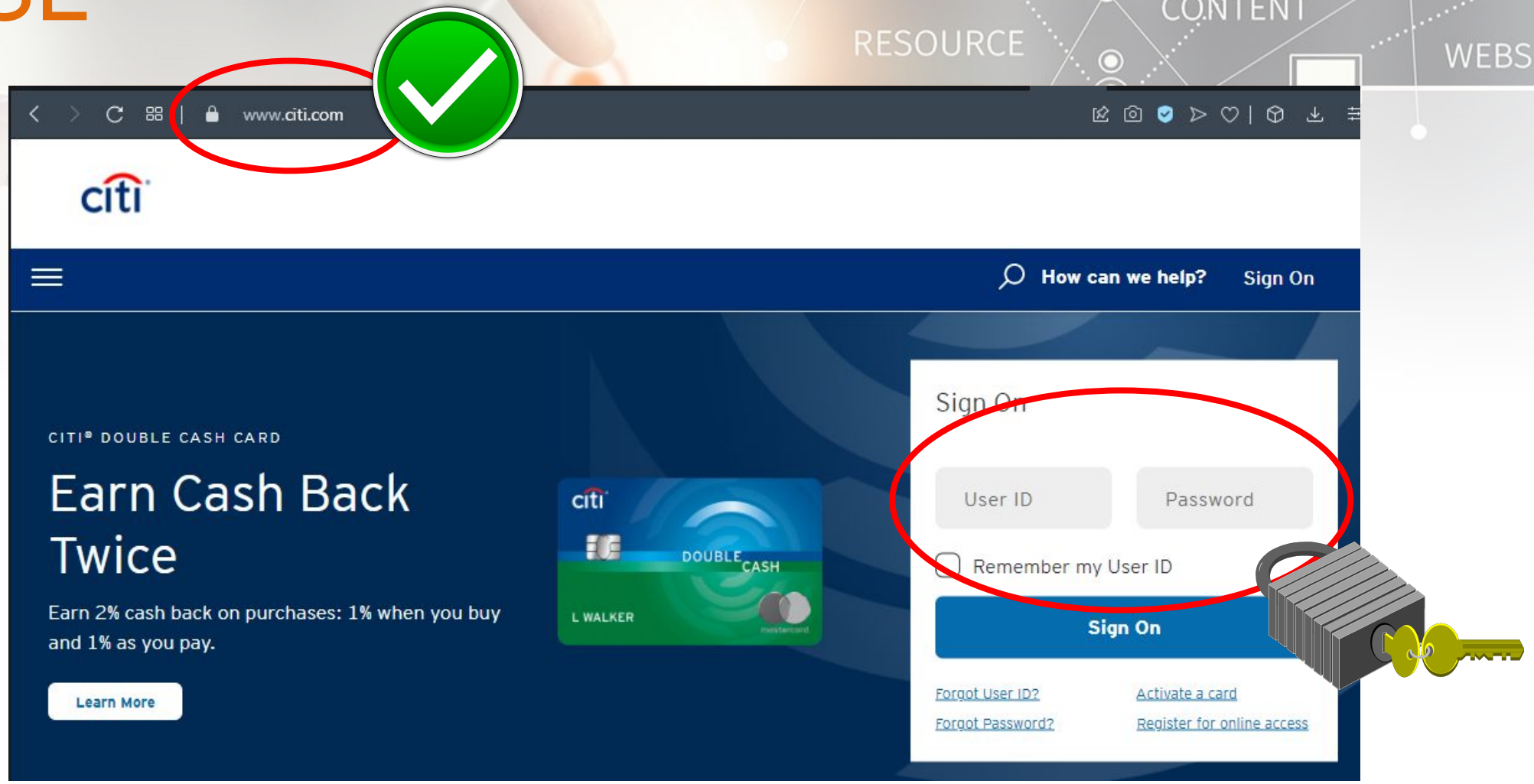
ACCOUNT
SEARCH
SEARCH
NETWORK
ACCOUNT
APPLICATION
COMMUNICATION
WEBSITE
SEARCH
CONTENT
MONITORING
CONTENT
RESOURCE
WEBSITE

TLS / SSL

SSL



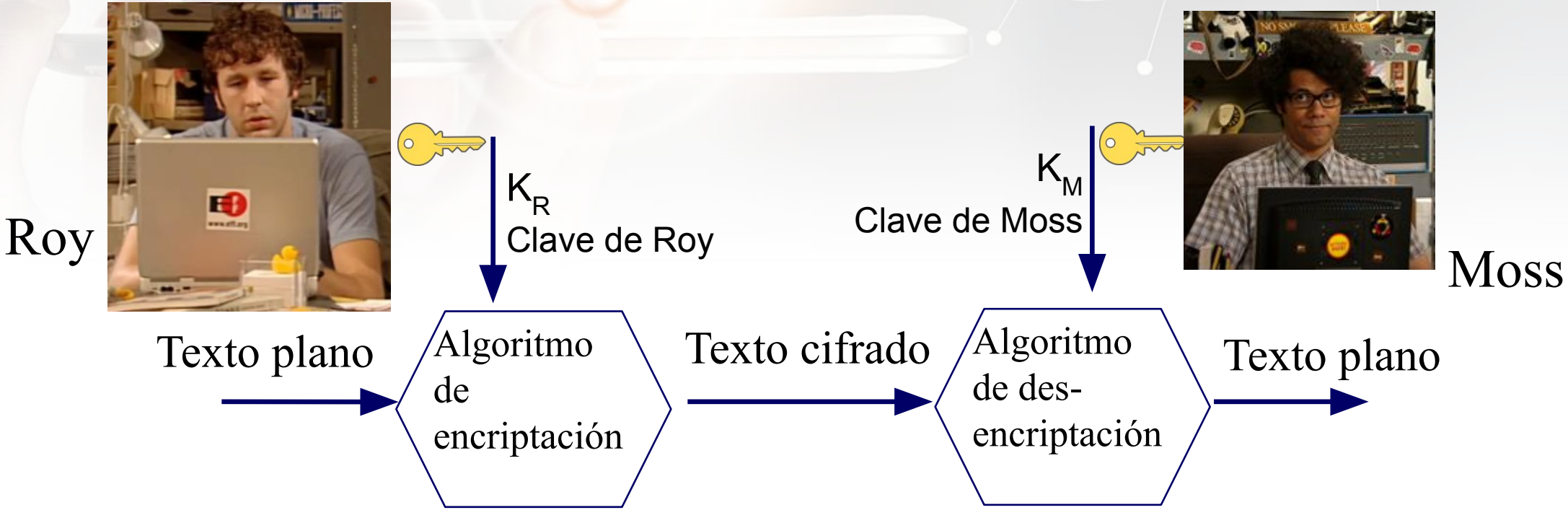
Para encriptar datos desde y hacia el servidor, un Web Server puede usar SSL (Secure Sockets Layer).

SSL

Secure Sockets Layer

- Desarrollado por Netscape en 1994
- RFC 6101 define SSL 3.0 (Agosto 2011)
- Una capa intermedia entre protocolos de aplicación y de transporte (TCP)
- Permite a un servidor que "hable" SSL autenticarse a sí mismo con un cliente que "hable" SSL
- Permite a un cliente autenticarse con un servidor
- Permite encriptar la conversación entre cliente y servidor

Nociones básicas de criptografía

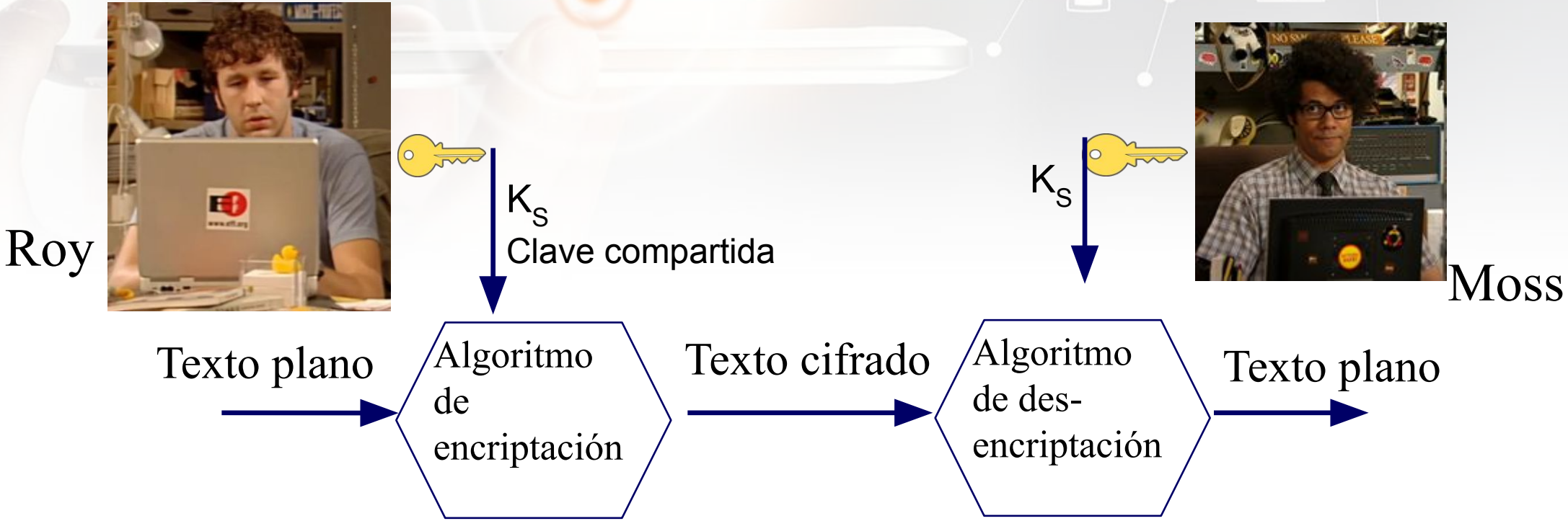


M: mensaje en texto plano

$K_R(M)$: mensaje cifrado con clave K_R

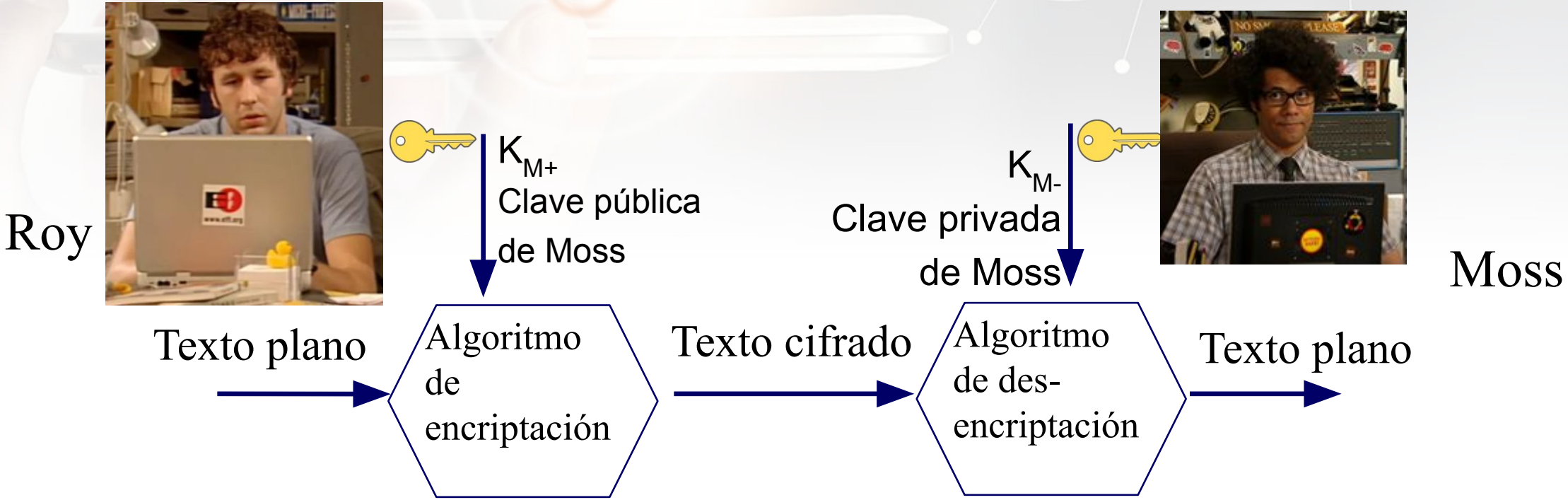
$M = K_M(K_R(M))$

Clave simétrica



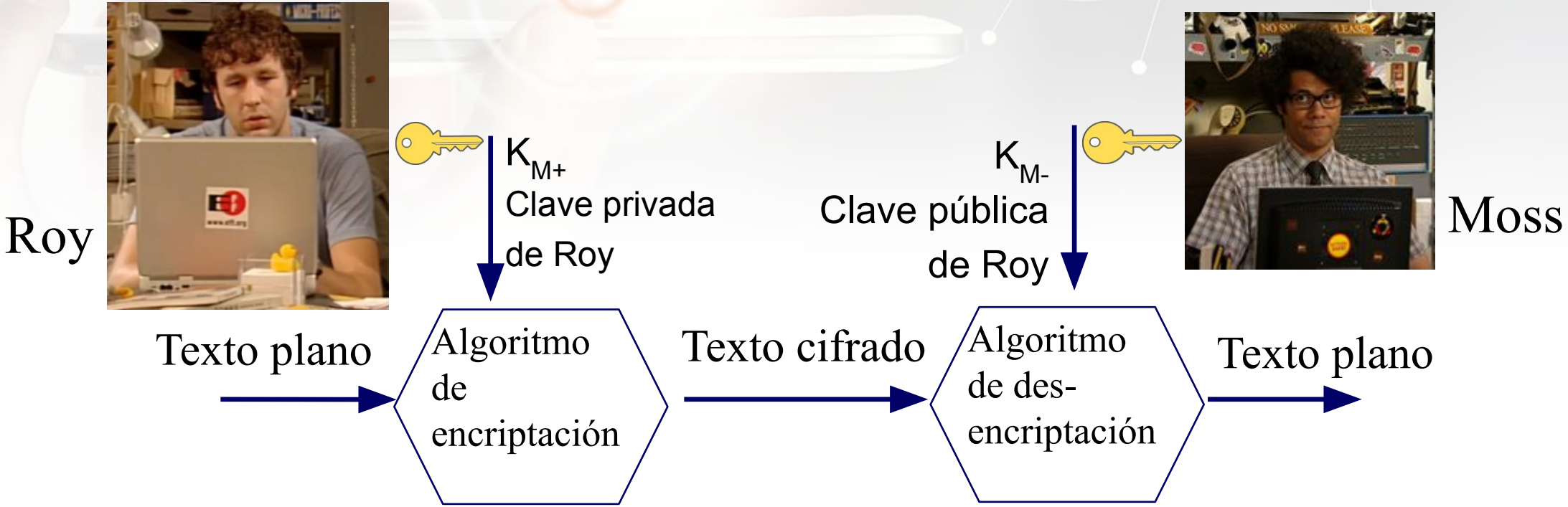
La clave que se usa para encriptar es la misma que se usa para desencriptar

Claves asimétricas



Un mensaje codificado con la clave pública de Moss sólo podrá desencriptarse con la clave privada de Moss.

Clave asimétrica



Un mensaje codificado con la clave privada de Roy sólo podrá desencriptarse con la clave pública de Roy.

Claves públicas

¿Cómo hace Roy para asegurarse que habla con Moss y no con alguien que se hace pasar por él?

Clave pública de Moss

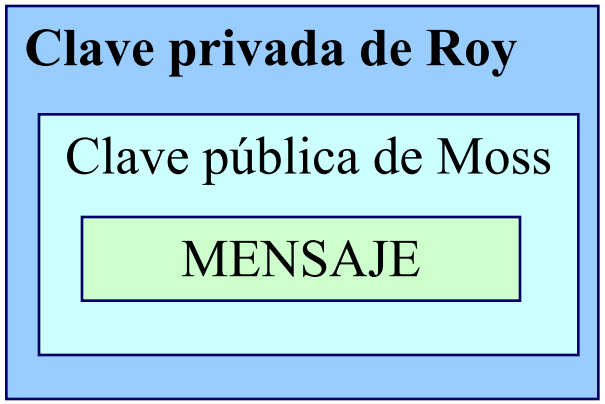
PassPhrase

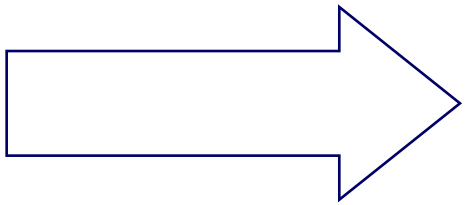
Clave privada de Moss

PassPhrase

Claves públicas

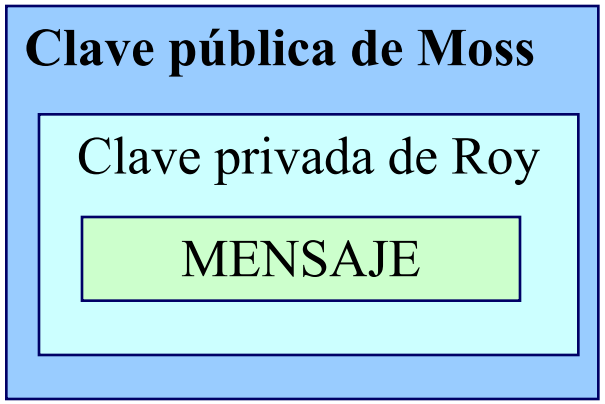
¿Cómo hace Roy para enviar un mensaje de forma tal que sólo lo pueda leer Moss y se asegure que sea de Roy?

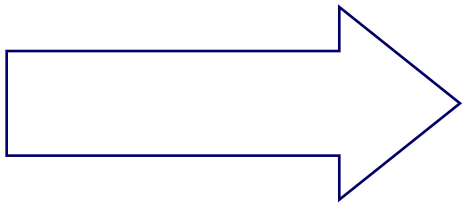




Claves públicas

¿Cómo hace Roy para enviar un mensaje de forma tal que sólo lo pueda leer Moss y se asegure que sea de Roy?





SSL

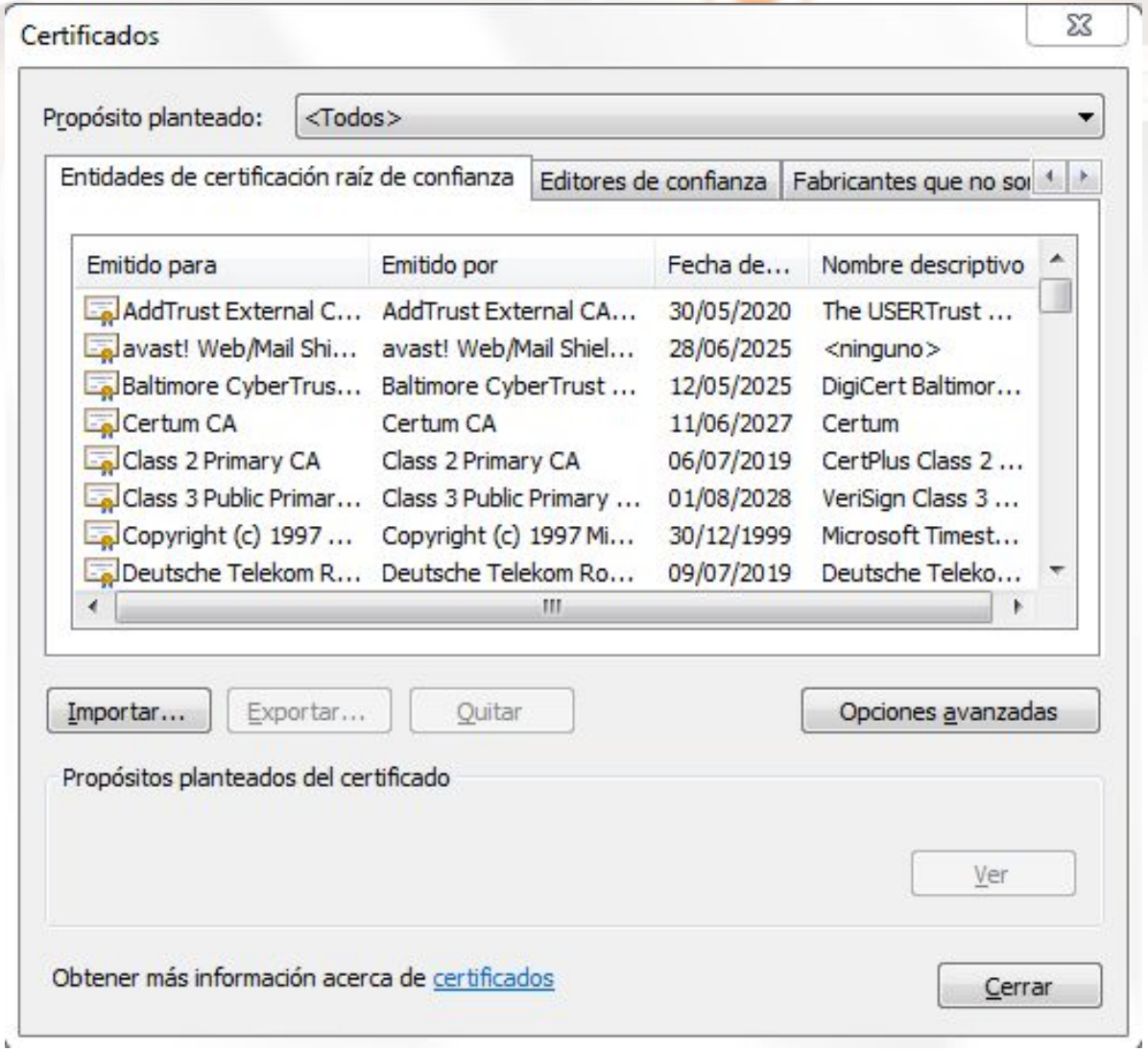
Creación de certificados

I. Crear una clave pública y privada
II. Crear un certificado que incluya la clave del servidor
III. Firmar el certificado, por un CA reconocido o por uno mismo.

¿Por qué aparece a veces?

The server's host key is not cached in the registry. You have no guarantee that the server is the computer you think it is.
The server's ssh-ed25519 key fingerprint is:
ssh-ed25519 255 2e:76:f8:f6:0e:f8:b0:0e:84:19:35:b1:e3:19:8b:cc
If you trust this host, hit Yes to add the key to PuTTY's cache and carry on connecting.
If you want to carry on connecting just once, without adding the key to the cache, hit No.
If you do not trust this host, hit Cancel to abandon the connection.

SSL: Listado de entidades certificantes.



Los certificados incluyen:

- La clave pública de la autoridad
- Los datos de la autoridad (nombre, e-mail)
- Período de vigencia
- Identificación del firmante
- Firma digital del firmante

SSL handshake

Solicitud de conexión segura (https://.....)

Envío de certificado X.509 conteniendo clave pública

Cliente verifica autenticidad del certificado

Cliente genera clave simétrica aleatoria y la encripta usando clave pública del servidor

Cliente y servidor conocen la clave simétrica y encriptan los datos con ella durante la sesión

SSL handshake

- Tipos de SSL Handshake
  - **Full Handshake**: Ocurre cuando cliente y servidor no tienen una sesión previa.
  - **Session Resumption**: Se reutiliza una sesión anterior para acelerar el proceso.

TLS

Transport Layer Security

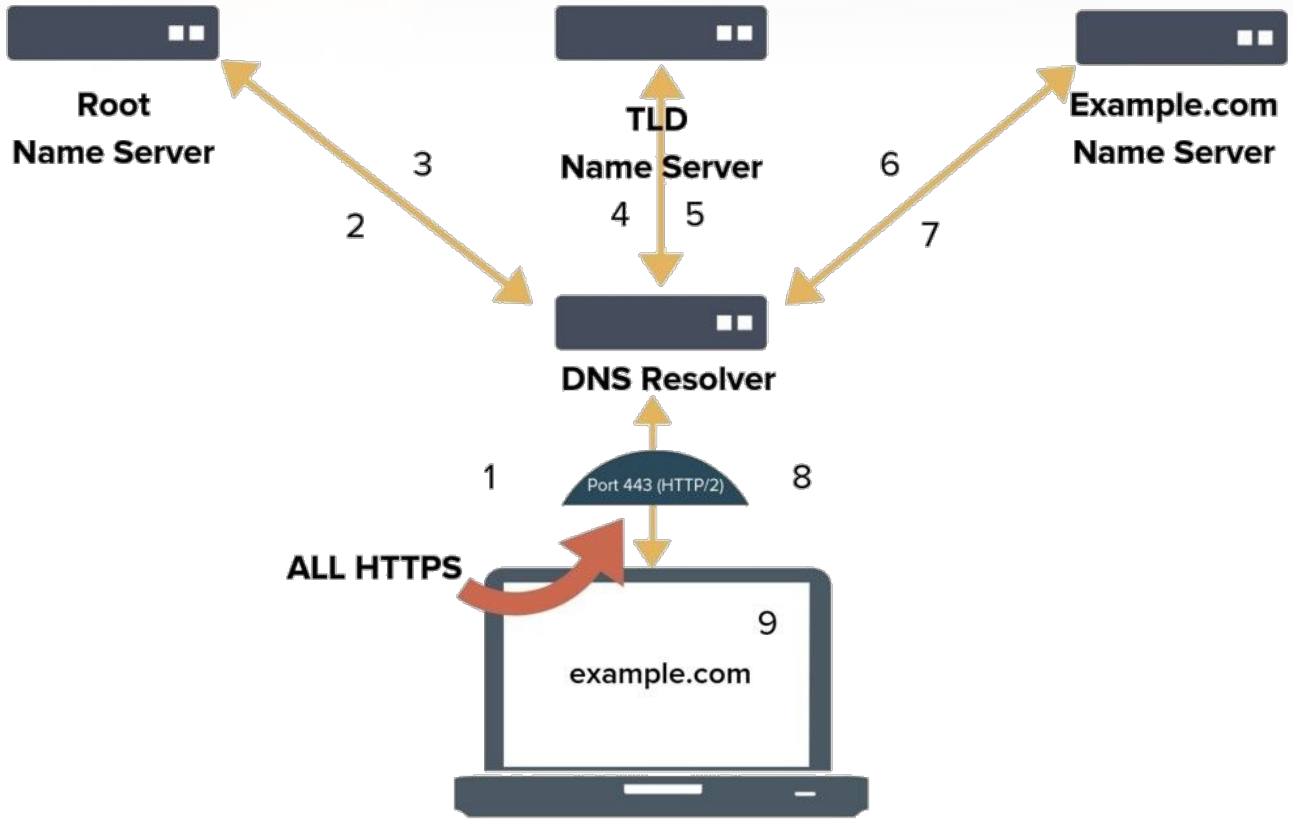
- TLS 1.0 está basado en SSL 3.0 (a veces TLS es llamado SSL 3.1)
- RFC 5246 define TLS 1.2
- Conexión segura por puerto: 443 para "*https*", 993 para "*IMAPs*", 995 para *"POPs"*, etc. Usa SSL
- Conexión segura por protocolo: comienza con un "hello" inseguro y luego cambia a una conexión segura. Ejemplo: comando STARTTLS en SMTP
- TLS y SSL proprocionan el mismo nivel de encriptación. Difieren en cómo se inicia la conexión segura.

DNS over TLS (DoT)

- Por defecto el puerto 853
- Incorporado en forma nativa en algunos Linux
- Dos modos:
  - modo estricto
  - modo de privacidad oportunista
- Soportado por algunos servidores:
  - ver https://dnsprivacy.org/wiki/display/DP/DNS+Privacy+Public+Resolvers

DNS over HTTPs (DoH)

- Se configura en cada browser que lo soporte (en Firefox está por defecto)
- RFC 8484
- El cliente usa GET o POST para enviar una query DNS codificada



HTTPs y proxy HTTP

- Los **proxies HTTP** se utilizan para **cachar contenido, filtrar accesos y mejorar el rendimiento**.
- Cuando el tráfico es **HTTP**, el proxy puede inspeccionar, modificar y almacenar las respuestas.
- Con **HTTPS**, el tráfico está cifrado entre el cliente y el servidor, lo que impide que un proxy vea el contenido directamente.
- Entonces, ¿cómo logran los proxies bloquear sitios o *cachear* contenido cifrado?

Intercepción HTTPS con MITM

- Para inspeccionar HTTPS, los proxies utilizan técnicas de ***"Man-in-the-Middle"*** **(MITM)**.
- Funcionamiento:
  1. El cliente inicia una conexión HTTPS a un sitio web.
  2. El proxy intercepta la conexión y genera un **certificado falso** en su lugar.
  3. Si el cliente confía en el certificado del proxy (porque fue instalado por el administrador de red), la conexión es aceptada.
  4. El proxy establece otra conexión segura con el servidor real y retransmite los datos.
- Esto permite que el proxy **lea y modifique** el contenido antes de reenviarlo al cliente.
- Es común en redes corporativas, escuelas y gobiernos para **filtrar contenido o aplicar políticas de seguridad**.

Detección y Problemas del MITM

- **Cómo detectar un proxy MITM:**
  - Verificar el **certificado SSL** en el navegador.
  - Si el emisor del certificado no es la entidad oficial (ejemplo: Let's Encrypt, DigiCert), podría ser un MITM.
  - Uso de herramientas como Wireshark o extensiones de navegador para inspeccionar la conexión.
- **Limitaciones del MITM:**
  - No funciona si el cliente no confía en el certificado del proxy.
  - Sitios con **HSTS (HTTP Strict Transport Security)** pueden rechazar conexiones con certificados no confiables.
  - Algunas aplicaciones y navegadores alertan sobre certificados sospechosos.

Filtrado sin inspección de contenido

- Aún sin romper el cifrado HTTPS, los proxies pueden:
  - **Bloquear sitios web** analizando el **SNI (Server Name Indication)** en el handshake TLS.
  - **Filtrar a nivel DNS**, evitando que los clientes resuelvan ciertos dominios.
  - Usar listas de **IP bloqueadas** de servidores sospechosos.
- Esto permite restringir accesos sin necesidad de ver el contenido real.

HTTPs y Proxies: conclusión

- Los proxies pueden inspeccionar HTTPS mediante **MITM**, pero requieren un certificado confiable en el cliente.
- Sin romper el cifrado, pueden bloquear sitios mediante **SNI, DNS o IPs bloqueadas**.
- Es una técnica utilizada en **empresas, gobiernos y redes educativas**.
- Los usuarios pueden detectar y mitigar MITM revisando certificados y usando herramientas de seguridad.